

Api Documentation

Table of Contents

REST API Documentation

Cache Behavior

Endpoint Reference

Python Analytics API Reference

Validation Evidence

Role Test Seed

JSON Examples

REST API Documentation

Node API base URI: `/api/v1`

Python Analytics API base URI: `/api/analytics/v1`

Common headers:

- `Content-Type: application/json`

- Authenticated endpoints require cookie `alc_session` or `Authorization: Bearer <session-token>`.
- Cookie-authenticated state changes also require the double-submit CSRF value; Bearer-authenticated API clients are exempt from the cookie CSRF check.
- `X-Request-Id` is accepted/generated and returned for operational traceability. Production errors do not expose stacks or database internals.
- Cache policy evidence is exposed with `X-Cache-Policy`.
- Server memory-cache evidence is exposed with `X-Memory-Cache`, `X-Memory-Cache-Key` and `X-Memory-Cache-TTL` when an endpoint uses the application cache.

Response envelope:

```
{ "success": true, "message": "OK", "data": {} }
```

```
{ "success": false, "message": "Validation failed", "details": {} }
```

Common status codes: `200`, `201`, `400`, `401`, `403`, `404`, `409`, `422`, `500`.

Cache Behavior

Endpoint or asset	Cache behavior
<code>GET /health/live</code> , <code>GET /health/ready</code>	Public but <code>no-store</code> ; readiness reflects current persistence state.
<code>GET /auth/config</code>	Public HTTP cache for 3600 seconds; safe because it only exposes OAuth client metadata.
Sensitive <code>/api/v1/*</code> responses	<code>Cache-Control: no-store, no-cache, must-revalidate, private</code> .

Endpoint or asset	Cache behavior
GET /roles , GET /permissions	Private HTTP cache plus in-memory cache for repeated catalog reads.
GET /branches , GET /dance-categories , GET /dance-styles	Private HTTP cache plus actor-scoped in-memory cache; writes invalidate related tags.
GET /reports/branches/su mmary	Private actor-scoped in-memory cache with short TTL; branch/student/attendance/evaluation writes invalidate report tags.
/assets/*	Public immutable cache for built frontend assets.
HTML pages and login page	Revalidate on every navigation.
GET /api/analytics/v1/he alth	Public short cache for 60 seconds.
Protected Python analytics endpoints	No-store.

Detailed cache evidence is documented in [03Documentation/cache-management.md](#).

Endpoint Reference

Method	URI	Description	Required Role	Params/Query	Body
GET	/health/live	Node process liveness probe.	Visitor	None	None
GET	/health/readiness	Node readiness probe.	Visitor	None	None

Method	URI	Description	Required Role	Params/Query	Body
GET	/auth/config	Public auth client configuration for the React login page.	Visitor	None	None
POST	/auth/login	Email/password login for existing academy users.	Visitor	None	{ "email": " password": "
POST	/auth/google	Google login for existing academy users.	Visitor	None	{ "idToken
GET	/auth/me	Current session user.	Authenticated	None	None
POST	/auth/change-password	Change the signed-in user's password.	Authenticated	None	{ "current wPassword": "
POST	/auth/logout	Revoke session and clear cookie.	Any	None	None

Method	URI	Description	Required Role	Params/Query	Body
GET	/public/branches	Public active branch catalog for the enrollment form.	Visitor	None	None
POST	/enrollment-requests	Public enrollment request.	Visitor	None	fullName, email, phone/branchId
GET	/enrollment-requests	List public requests.	BranchDirector, GeneralDirector, Admin	None	None
PATCH	/enrollment-requests/{id}/status	Advance a lead through the academy pipeline.	BranchDirector, GeneralDirector, Admin	Path <code>id</code>	status, optional
GET	/users	List users.	GeneralDirector, Admin	None	None

Method	URI	Description	Required Role	Params/Query	Body
POST	/users	Create an academy user with a temporary password.	GeneralDirector, Admin	None	email, name, role, branchIds, studentIds
PATCH	/users/{id}/role	Assign internal role.	Admin	Path id	{ "role": "Internal" }
GET	/users/{id}/branch-accesses	List branch access assigned to a user.	GeneralDirector, Admin	Path id	None
PATCH	/users/{id}/branch-accesses	Replace branch access assigned to a user.	GeneralDirector, Admin	Path id	{ "branchIds": [1, 2] }

Method	URI	Description	Required Role	Params/Query	Body
GET	/roles	List roles.	Authenticated	None	None
GET	/permissions	List permissions.	GeneralDirector, Admin	None	None
GET	/branches	List branches.	Authenticated	None	None
POST	/branches	Create branch.	GeneralDirector, Admin	None	name, city, activ
PATCH	/branches/{id}	Update branch.	GeneralDirector, Admin	Path <code>id</code>	partial branch
GET/POST/PATCH	/students	List/create/update students.	Read: scoped authenticated. Write: scoped directors/admin	Path <code>id</code> on item routes	userId, branchId
GET/POST/PATCH	/teachers	List/create/update teachers.	Read: scoped authenticated. Write: scoped directors/admin	Path <code>id</code>	userId, branchId

Method	URI	Description	Required Role	Params/Query	Body
GET/POST/PATCH	/dance-categories	Manage dance categories.	Read: authenticated. Write: GeneralDirector/Admin	Path <code>id</code>	name
GET/POST/PATCH	/dance-styles	Manage dance styles.	Read: authenticated. Write: GeneralDirector/Admin	Path <code>id</code>	categoryId, name
GET/POST/PATCH	/class-groups	Manage class groups.	Read: scoped authenticated. Write: scoped directors/admin	Path <code>id</code>	branchId, optional capacity
GET/POST/PATCH	/class-sessions	Manage scheduled sessions.	Read: scoped authenticated. Write: scoped directors/admin	Path <code>id</code>	classGroupId, optional cancellationReason
GET/POST/PATCH	/branch-events	Manage branch events and show income.	Read: scoped authenticated. Write: scoped directors/admin	Path <code>id</code>	branchId, title, description, location, showIncome

Method	URI	Description	Required Role	Params/Query	Body
DELETE	/academy-events/{id}	Soft-remove an event.	BranchDirector, GeneralDirector, Admin	Path <code>id</code>	None
GET	/class-group-enrollments	List visible group memberships/history.	Authenticated	None	None
POST	/class-group-enrollments	Enroll or re-enroll a student in a group.	BranchDirector, GeneralDirector, Admin	None	studentId, classId, status/startsAt/endsAt

Method	URI	Description	Required Role	Params/Query	Body
PATCH	/class-attendance/{id}	Move one enrollment episode through its lifecycle.	BranchDirector, GeneralDirector, Admin	Path <code>id</code>	status/startsAt/endsAt
GET	/class-session/{id}/roster	Load the session's historical roster and current marks.	Teacher, BranchDirector, GeneralDirector, Admin	Path <code>id</code>	None
PUT	/class-session/{id}/attendance	Save a draft or finalize roster attendance.	Teacher, BranchDirector, GeneralDirector, Admin	Path <code>id</code>	state (<code>draft</code>), correctionReason

Method	URI	Description	Required Role	Params/Query	Body
GET	/student-payments/{id}	List/read visible financial ledger rows.	Authenticated	Optional path <code>id</code>	None
POST	/student-payments	Create a charge.	BranchDirector, GeneralDirector, Admin	None	studentId, amount, paidAt/dueAt/notes
PATCH	/student-payments/{id}	Correct or collect an unposted charge.	BranchDirector, GeneralDirector, Admin	Path <code>id</code>	partial charge payload, terms/cancellation

Method	URI	Description	Required Role	Params/Query	Body
POST	/student-payments/{id}/reversal	Reverse a posted paid charge.	GeneralDirector, Admin	Path <code>id</code>	{ "reason"
PATCH/DELETE	/students/me/profile-photo	Set or remove own student photo.	Student	None	PATCH: <code>profile</code>
GET	/student-attendance	List visible student attendance records.	Authenticated	None	None

Method	URI	Description	Required Role	Params/Query	Body
POST	/student-attendance	Record one attendance mark (compatibility flow).	Teacher, BranchDirector, GeneralDirector, Admin	None	studentId, classId, correctionReason
GET	/teacher-attendance	List visible teacher shifts.	Teacher, BranchDirector, GeneralDirector, Admin	None	None
POST	/teacher-attendance/check-in	Teacher check-in.	Teacher, BranchDirector, GeneralDirector, Admin	None	teacherId, classId

Method	URI	Description	Required Role	Params/Query	Body
PATCH	/teacher-attendance/{id}/check-out	Teacher check-out.	Teacher, BranchDirector, GeneralDirector, Admin	Path <code>id</code>	None
GET	/absence-justifications	List visible absence justifications.	Authenticated	None	None
POST	/absence-justifications	Submit absence justification.	Student, Teacher, directors/admin	None	attendanceReco evidenceUrl

Method	URI	Description	Required Role	Params/Query	Body
PATCH	/approve-justifications/{id}/review	Approve/reject justification.	BranchDirector, GeneralDirector, Admin	Path <code>id</code>	status, optional
GET	/reports/branches/summary?from=&to=	Branch summary report.	BranchDirector, GeneralDirector, Admin	Optional ISO period	None
GET	/reports/general?from=&to=	Consolidated management report.	GeneralDirector, Admin	Optional ISO period, maximum 1095 days	None

Method	URI	Description	Required Role	Params/Query	Body
GET	/reports/branches/{branchId}/details?from=&to=	Single-branch management report.	BranchDirector, GeneralDirector, Admin	Path branch and optional ISO period	None

Method	URI	Description	Required Role	Params/Query	Body
GET	/reports/scholarships/{studentId}/candidate?from=&to=	Scholarship candidate check.	BranchDirector, GeneralDirector, Admin	Path studentId, optional ISO dates	None
POST	/scholarship-evaluations	Register scholarship evaluation.	BranchDirector, GeneralDirector, Admin	None	studentId, perce approved, optio

Method	URI	Description	Required Role	Params/Query	Body
GET	/scholarship-evaluations	List scholarship evaluations.	BranchDirector, GeneralDirector, Admin	None	None
GET	/reports/level-promotions/{studentId}/candidate?from=&to=	Level promotion candidate check.	BranchDirector, GeneralDirector, Admin	Path studentId, optional ISO dates	None

Method	URI	Description	Required Role	Params/Query	Body
POST	/le vel -pr omo tio n-e val uat ion s	Register promotion evaluation.	BranchDirector, GeneralDirector, Admin	None	studentId, consi practiceScore, a
GET	/le vel -pr omo tio n-e val uat ion s	List promotion evaluations.	BranchDirector, GeneralDirector, Admin	None	None

Method	URI	Description	Required Role	Params/Query	Body
GET	/reports/teachers/{teacherId}/payments?from=&to=	Teacher payment calculation.	BranchDirector, GeneralDirector, Admin	Path teacherId and optional ISO dates	None
GET	/audit-logs	Filter/paginate audit logs.	GeneralDirector, Admin	action, entity, actorUserId, from, to, limit 1-200, offset	None

Python Analytics API Reference

The Python Analytics API is implemented with FastAPI under `06Code/python-analytics-api`. It reuses the JWT session token issued by the Node Auth API and enforces the same resource-scope policy for students, teachers and assigned branches.

Method	URI	Description	Required Role	Params/Query	Body	Success	Business/Val
GET	/api/analystics/v1/health	Python API health check.	Visitor	None	None	200 service status	Confirms Fast service is alive Cache-Control: public -age=60.
GET	/api/analystics/v1/students/{student_id}/attendance-risk	Student attendance risk analytics.	Scoped authenticated	Path student_id ; optional from , to ISO datetimes	None	200 attendance rate, risk level, recommendation	Student sees data; Teacher students from taught session BranchDirect assigned bran

Method	URI	Description	Required Role	Params/Query	Body	Success	Business/Val
GET	/api/analytical/tytcs/v1/students/{student_id}/scholarship-readiness	Scholarship readiness analytics.	Scoped authenticated	Path <code>student_id</code> ; optional <code>from</code> , <code>to</code> ISO datetimes	None	<code>200</code> attendance threshold comparison	Uses the active scholarship resource-scope authorization

Method	URI	Description	Required Role	Params/Query	Body	Success	Business/Val
GET	/api/analyticals/v1/branches/{branch_id}/performance-summary	Branch performance analytics.	BranchDirector, GeneralDirector, Admin	Path <code>branch_id</code>	None	<code>200</code> branch totals, attendance rate, performance level	BranchDirector be assigned to requested branch

Method	URI	Description	Required Role	Params/Query	Body	Success	Business/Val
GET	/api/analytical-teacher-workload-summary	Teacher workload analytics.	Scoped authenticated	Path <code>teacher_id</code> ; optional <code>from</code> , <code>to</code> ISO datetimes	None	<code>200</code> check-ins, completed hours, estimated pay	Teacher sees workload; BranchDirect assigned bar teachers.

Validation Evidence

- Automated API validation command: `cd 06Code && npm run test:api:validation`
- Latest generated report: `03Documentation/api-validation-report.md`
- Latest JSON result evidence: `070ther/api-validation-results.json`
- Manual Postman verification assets: `postman/American-Latin-Class-API.postman_collection.json` , `postman/American-Latin-Class-Analytics-API.postman_collection.json` and `postman/American-Latin-Class.postman_environment.json`

The automated suites cover fail-closed configuration, liveness/readiness behavior, password and Google login, first-password rotation, JWT/session revocation, CSRF/cookie behavior, RBAC/resource scope, public lead validation, academic CRUD, enrollment/capacity/waitlist, session conflicts/lifecycle, roster draft/final/correction, teacher shift/payroll controls, absence review, financial ledger/reversals, rule evaluation, report formulas/data-quality alerts and filtered audit visibility.

Role Test Seed

Run this after applying the database schema when you need manual role/permission testing:

```
cd 06Code
npm run db:seed:role-test
```

The seed requires explicit local `SEED_*_EMAIL` and `SEED_*_PASSWORD` values. It is blocked outside an opted-in localhost development database, marks password accounts for mandatory rotation and never prints credentials.

JSON Examples

Email/password login:

```
{
  "email": "local-admin@example.invalid",
  "password": "{{login_password}}"
}
```

Google login:

```
{
  "idToken": "eyJhbGciOi..."
}
```

Create academy account:

```
{
  "email": "new-student@example.invalid",
  "name": "Student Name",
  "role": "Student",
  "temporaryPassword": "<one-time-secret>"
}
```

Change temporary password:

```
{
  "currentPassword": "<one-time-secret>",
  "newPassword": "<new-unique-secret>"
}
```

Login response in test or explicitly opted-in local API-client mode (deployed responses omit `sessionToken` and `tokenType`):

```
{
  "success": true,
  "message": "Login successful",
  "data": {
    "sessionToken": "eyJhbGciOi...",
    "tokenType": "Bearer",
    "expiresInMinutes": 120,
    "user": {
      "id": "<user-id>",
      "email": "student@example.invalid",
      "name": "Student Example",

```

```
    "role": "Student",  
    "mustChangePassword": true  
  }  
}
```

Postman authenticated request:

```
GET /api/v1/auth/me  
Authorization: Bearer {{session_token}}
```

Logout invalidates the backend session:

```
POST /api/v1/auth/logout  
Authorization: Bearer {{session_token}}
```

After logout, the same token must return **401**:

```
GET /api/v1/auth/me  
Authorization: Bearer {{session_token}}
```

Python analytics authenticated request:

```
GET /api/analytics/v1/students/{{student_id}}/attendance-risk  
Authorization: Bearer {{session_token}}
```

Python analytics unauthorized response:

```
{  
  "success": false,  
  "message": "Authentication required",  
}
```

```
"data": null
}
```

Student attendance:

```
{
  "studentId": "85f4bbe9-5d5f-4126-89b6-ddd9de432885",
  "classSessionId": "76f37581-dbbc-4201-bb13-67fbc86f6d60",
  "status": "present",
  "notes": "On time"
}
```

Finalize a complete roster (use `draft` while it is incomplete):

```
{
  "state": "finalized",
  "records": [
    { "studentId": "85f4bbe9-5d5f-4126-89b6-ddd9de432885", "status":
      "present", "notes": "On time" }
  ]
}
```

Scholarship evaluation:

```
{
  "studentId": "85f4bbe9-5d5f-4126-89b6-ddd9de432885",
  "percentage": 50,
  "theoryScore": 82,
  "practiceScore": 91,
  "approved": true
}
```

Error response:

```
{  
  "success": false,  
  "message": "Insufficient permissions",  
  "details": null  
}
```